

Perancangan Sistem Keamanan & Keterlacakan Terintegrasi

Modul 4.4 – Level 4 (Mastery) – Transformasi Tata Kelola Kearsipan

PUSAT PENDIDIKAN DAN PELATIHAN
PT PLN (Persero)

2026



Target Peserta

Modul ini ditujukan secara khusus bagi:

- **Manajemen Atas (MA)** PT PLN (Persero).
- Unit Kearsipan, IT Governance, GCG, Manajemen Risiko.
- Pengambil Kebijakan Tata Kelola Keamanan Informasi.

Prasyarat Peserta

Untuk efektivitas pembelajaran, peserta diharapkan:

- Lulus **Modul 4.1–4.3** (arsitektur & optimalisasi).
- Memahami klasifikasi arsip dasar & familiar SSO/SAP.
- Membawa contoh kebijakan keamanan unit untuk studi kasus.

Kompetensi Akhir Modul 4.4

Setelah menyelesaikan pelatihan ini, peserta ditargetkan mampu:

1

Merancang RBAC Terintegrasi

Skema kontrol akses berbasis peran yang terhubung dengan sistem kepegawaian/SSO.

2

Merancang Audit Trail

Mekanisme log otomatis, 4W metadata, hash chain, & SIEM.

3

Merumuskan Kebijakan ISMS

Kebijakan keamanan arsip selaras ISO 27001, NIST, & GCG BUMN.

4

Merancang Backup & DR

Strategi 3-2-1, RTO/RPO, BCP, & simulasi pemulihan.



Bagian I: Fondasi & Urgensi

5 menit

1

Konteks & Urgensi

Serangan siber, regulasi, GCG.

2

Arsitektur 4 Pilar

RBAC, Audit, ISMS, Backup/DR.

Bagian II: Empat Pilar Keamanan

37 menit

3

Pilar 1: RBAC

4

Pilar 2: Audit Trail

5

Pilar 3: Kebijakan ISMS

6

Pilar 4: Backup & DR

Bagian III: Studi Kasus & Validasi

3 menit

7

Studi Kasus Integratif

Insiden kebocoran arsip.

8

Portofolio & Kendali Manajemen

Rubrik, komitmen, tindak lanjut.

Durasi fasilitasi: 45 menit (Fondasi 5· RBAC 10· Audit 10· ISMS 10· DR 7· Kasus 3), workshop mandiri 4×30 menit



Ancaman yang Terus Meningkat

- **2021:** 1,63 miliar anomali serangan siber (BSSN).
- **Jan–Jul 2025:** 3,64 miliar anomali — BUMN jadi target utama.
- Kebocoran kontrak strategis = kerugian finansial + sanksi regulasi.

Risiko Ganda

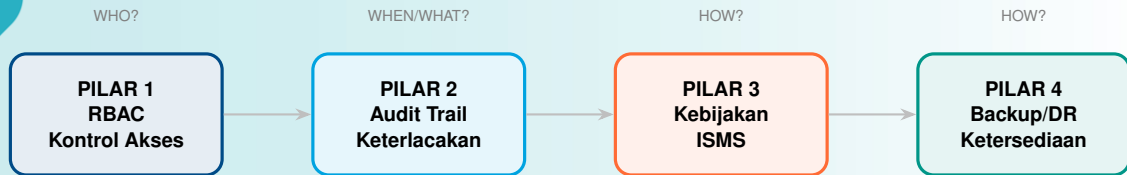
- 1 **Operasional:** Kehilangan aset informasi kritis.
- 2 **Regulasi:** Sanksi OJK, BPK, ANRI, temuan audit.

Implikasi GCG

Kegagalan menjaga keamanan arsip langsung memengaruhi penilaian **TARIF** BUMN:

- **Transparansi** audit trail
- **Akuntabilitas** keputusan
- **Responsibilitas** kepatuhan

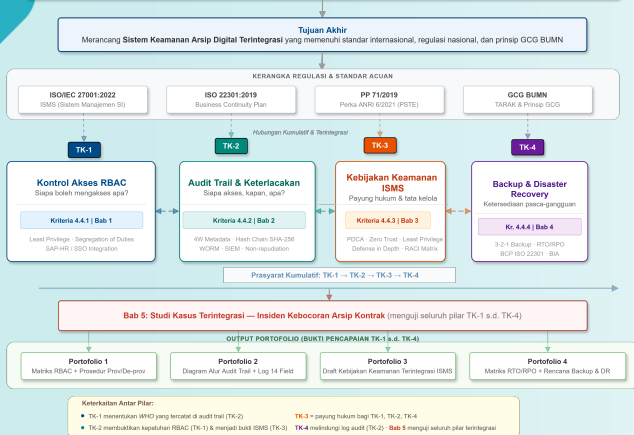




Pandangan Strategis

Keempat pilar harus dirancang **bersamaan**, bukan berurutan oleh unit yang berbeda tanpa koordinasi. Solusi parsial = celah keamanan yang tidak terdeteksi hingga terjadi insiden.

Kerangka Berpikir — Modul 4.4: Keamanan & Keterlacakan Terintegrasi



Peta Jalan Kompetensi

- TK-1 (Bab 1):** Siapa yang boleh mengakses?
- TK-2 (Bab 2):** Kapan & apa yang dilakukan?
- TK-3 (Bab 3):** Payung hukum & tata kelola.
- TK-4 (Bab 4):** Jamin ketersediaan pasca-gangguan.

Puncak Pembelajaran

Studi Kasus Bab 5 menguji apakah keempat pilar diterapkan secara sinergis.

Pilar 1:

Kontrol Akses Berbasis Peran (RBAC)

Modul 4.4: Keamanan & Keterlacakan Terintegrasi

1

Least Privilege

Hak akses minimum yang benar-benar diperlukan. Staf TU tidak perlu hak Export terhadap arsip Rahasia jika tugasnya hanya Read.

2

Segregation of Duties

Tidak ada satu peran yang memiliki kombinasi hak berlebihan: Create, Approve, & Export harus terpisah.

3

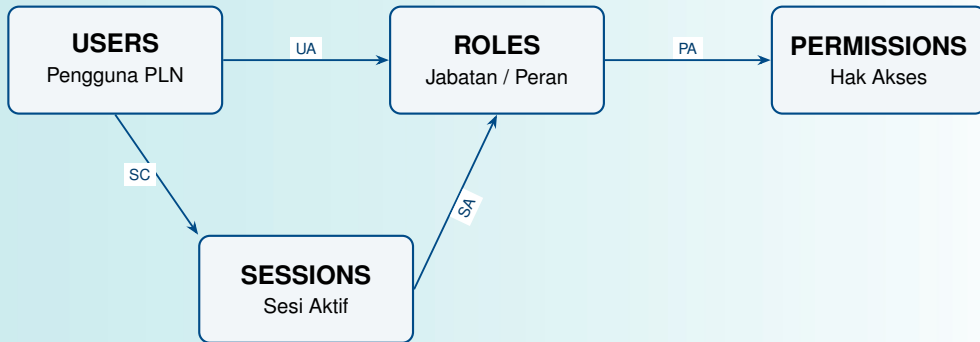
Break-Glass

Akses darurat di luar hak normal, dengan pencatatan audit trail lengkap & persetujuan atasan pasca-kejadian.

Mengapa RBAC = Fondasi Keterlacakan?

Tanpa kontrol akses terstruktur, log audit menjadi tidak bermakna. RBAC memastikan setiap jejak digital merepresentasikan tindakan pihak yang **berwenang**.





Insight

Hak akses tidak diberikan langsung ke individu, melainkan ke **peran** (role). Pendekatan ini mempermudah manajemen siklus hidup akses: provisioning saat mutasi & de-provisioning saat pensiun.

Peran	Publik	Terbatas	Rahasia	Vital
Staf Kearsipan	C, R	R	R [†]	–
Staf Administrasi/TU	C, R	R	–	–
Kabag TU / Kasubag	C, R, U	C, R, U	R, E	R
Staf Hukum / Legal	C, R	C, R, U	R, E	R
Staf IT / DBA	–	R	R	R [†]
GM / SRM Unit	R	R, U	R, U, A	R, U, A
Auditor SPI	R	R, E	R, E	R, E
VP Cyber Security	R	R, E	R, E	R, E

C=Create, R=Read, U=Update, A=Approve, E=Export/Review. [†] Dengan persetujuan atasan.

Arah Manajemen Atas

Validasi: tidak ada satu peran yang sekaligus Create, Approve, & Export arsip Vital tanpa mekanisme pengawasan.

Tata Kelola bagi MA

- 1 **Inventarisasi Peran** – Validasi kelengkapan daftar peran.
- 2 **Pemetaan Aset** – Tetapkan klasifikasi 4 tingkat (Vital, Rahasia, Terbatas, Publik).
- 3 **Penetapan Hak Minimum** – Tim IT + Kearsipan susun matriks; MA setuju.

Validasi Kritis

- 4 **Segregation of Duties** – Pastikan tidak ada konflik kepentingan.
- 5 **Provisioning/De-provisioning** – Terhubung SAP-HR/SSO.
- 6 **Review Berkala** – Minimal tahunan, hasilnya didokumentasikan.

Pertanyaan Kunci: “Apakah hak akses langsung dicabut saat mutasi/pensiun tanpa menunggu keluhan?”

Workshop 1 (30 Menit)

- 1 Identifikasi 3 peran kunci di unit Anda yang bersentuhan dengan arsip.
- 2 Tentukan hak akses (CRU) untuk 3 klasifikasi arsip operasional.
- 3 Rancang mekanisme review & revokasi akses tahunan.

Portofolio 1

Matriks RBAC Terintegrasi + Prosedur Provisioning/De-provisioning.

Kriteria: 4.4.1 – kejelasan role, least privilege, integrasi HR/SSO.



Pilar 2:

Audit Trail Otomatis & Keterlacakan

Modul 4.4: Keamanan & Keterlacakan Terintegrasi



Analogi

RBAC mengontrol siapa yang boleh masuk pintu. Audit trail adalah **kamera CCTV** yang merekam setiap orang yang masuk, kapan, dan melakukan apa.

SIEM

Security Information & Event Management – “kamera pengawas digital” yang mengubah ribuan log mentah menjadi informasi yang dapat ditindaklanjuti secara pro-aktif.

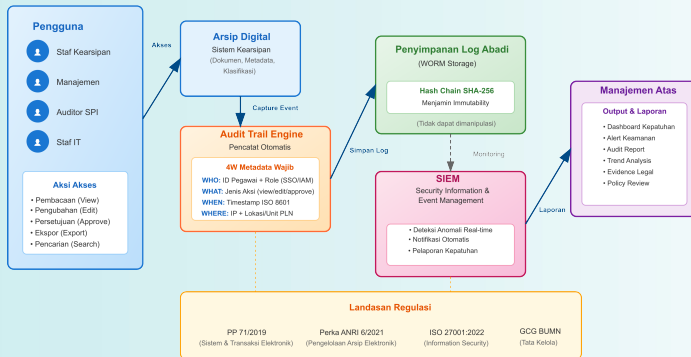
Hash Chain

Setiap entri log dihubungkan secara kriptografis. Jika 1 byte diubah, seluruh rantai hash berikutnya **gagal verifikasi** — manipulasi langsung terdeteksi.

Diagram Alur Audit Trail Sistem Arsip Digital PLN

Diagram Alur Audit Trail Sistem Arsip Digital

Dari Akses Pengguna hingga Penyimpanan Log Immutable



WHO	WHAT	WHEN	WHERE
ID Pegawai + Role (SSO)	Aksi: view/edit/export	Timestamp ISO 8601	IP + Lokasi Unit

Wajib (12 Field)

- DOC_ID – ID Dokumen Unik
- TIMESTAMP – Waktu Aksi (ISO 8601)
- HASH_SHA256 – Nilai Hash Integritas
- CREATOR_ROLE – Peran Pengguna (IAM/SSO)
- AUDIT_LOG_ID – ID Log Immutable
- CLASSIFICATION – Tingkat Keamanan
- RETENTION_RULE – Aturan Retensi
- ASSET_ID – Referensi Aset PLN
- CONTRACT_REF – Referensi Kontrak
- LOCATION_GIS – Lokasi Operasional
- INTEGRITY_HASH – Verifikasi Perubahan
- AUDIT_TRAIL_REF – Log Terkait

Semi-Mandatory (2 Field)

- CONTENT_DESC – Ringkasan Isi (NLP/Input)
- SEARCH_TAGS – Kata Kunci Terkontrol

Regulasi

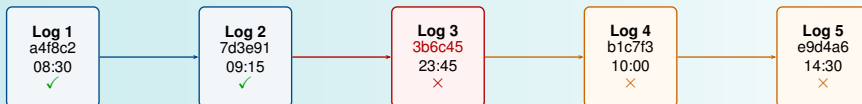
Memenuhi PP 71/2019 & Perka ANRI 6/2021.



Hash Chain: Immutability Log Audit

Hash Chain: Immutability Log Audit

Modifikasi 1 byte merusak rantai



INTEGRITAS TERDETEKSI RUSAK

Pesan untuk MA

Hash SHA-256 menjamin deteksi perubahan 1 byte seketika. Log disimpan terpisah (WORM). Setiap approval wajib **TTE** untuk kekuatan hukum non-repudiation.

Tata Kelola

- 1 **Cakupan & Retensi** – Minimal arsip Rahasia/Vital; retensi = masa retensi arsip.
- 2 **Validasi Metadata** – Pastikan 14 field tercatat; minta bukti laporan log.
- 3 **Mekanisme Pemantauan** – SIEM: mingguan (Vital), bulanan (Rahasia).

Eskalasi & Kepatuhan

- 4 **Eskalasi** – Siapa dihubungi dalam 1 jam / 4 jam / 24 jam?
- 5 **Kepatuhan Regulasi** – PP 71/2019 & Perka ANRI 6/2021.

Pertanyaan Kunci: “Jika hari ini terjadi kebocoran, bisakah kita tunjukkan siapa yang mengakses dalam 6 bulan terakhir?”

Workshop 2 (30 Menit)

- 1 Gambar alur audit trail: penciptaan → validasi → penyimpanan.
- 2 Lengkapi template 14 field untuk 1 jenis arsip kritis.
- 3 Tentukan mekanisme eskalasi jika hash integrity gagal.

Portofolio 2

Diagram Alur Audit Trail + Template Log 14 Field.

Kriteria: 4.4.2 – kelengkapan 4W, immutability, compliance regulasi.

Pilar 3:

Kebijakan Keamanan Terintegrasi dengan ISMS

Modul 4.4: Keamanan & Keterlacakan Terintegrasi



Analogi

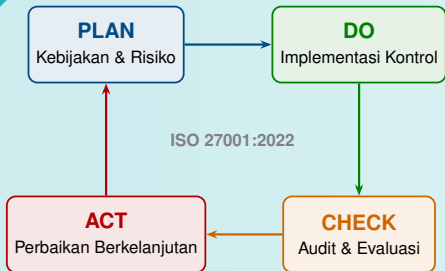
RBAC = Pintu & Kunci. Audit Trail = CCTV. Kebijakan = **Peraturan Perusahaan** yang memberikan kekuatan hukum agar pintu tidak dibuka sembarangan dan CCTV tidak dimatikan.

ISO/IEC 27001:2022

93 kontrol keamanan dalam 4 kelompok: Organizational, People, Physical, Technological. Arsip digital = Aset Informasi Kritis.

NIST

Cybersecurity Framework, SP 800-53, SP 800-207 (Zero Trust). Referensi praktis global untuk perancangan kebijakan.



Penerapan di PLN

- **Plan** – Rancang kebijakan keamanan arsip, identifikasi risiko.
- **Do** – Implementasi RBAC, backup, pemantauan.
- **Check** – Audit internal & evaluasi kepatuhan.
- **Act** – Perbaikan berdasarkan temuan & insiden.

1

Least Privilege

Hak akses minimum. Setiap permintaan diverifikasi eksplisit.

2

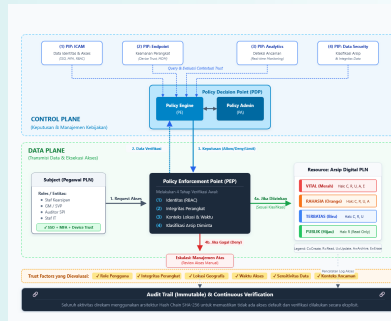
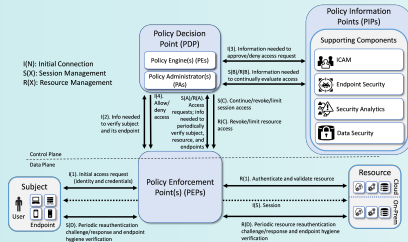
Defense in Depth

5 lapisan: Kebijakan → Fisik → Jaringan → Aplikasi → Data.

3

Zero Trust

Tidak ada akses default. Verifikasi berkelanjutan berdasarkan konteks (role, device, lokasi, waktu).



Prinsip TARIF	Implementasi dalam Kebijakan Arsip
Transparansi	Audit trail dapat diakses Auditor Internal/Eksternal sesuai kewenangan
Akuntabilitas	RACI digital jelas; setiap aksi terikat identitas & TTE
Responsibilitas	Kepatuhan PP 71/2019 & Perka ANRI 6/2021 wajib diuji berkala
Independensi	Unit Kearsipan berwenang tolak arsip tidak memenuhi standar metadata
Fairness	Akses berbasis need-to-know, tidak diskriminatif, ada mekanisme banding

Manajemen Atas sebagai Penandatanganan

Kebijakan yang tidak ditinjau secara berkala (minimal tahunan) akan menjadi usang dan kehilangan kekuatan hukumnya.

Klausul 1–3

- **Ruang Lingkup** – Seluruh arsip digital unit.
- **Kontrol Akses** – RBAC, least privilege, provisioning.
- **Audit Trail** – 14 field, immutable, retensi sesuai arsip.

Klausul 4–6

- **Backup & Pemulihan** – Strategi 3-2-1, RTO/RPO, simulasi 6 bulanan.
- **Peran & Tanggung Jawab** – RACI: Accountable = GM/SVP.
- **Kepatuhan & Peninjauan** – Audit internal, review tahunan.

Insight

Kebijakan harus terintegrasi dengan ISMS organisasi (ISO 27001), bukan dokumen yang berdiri sendiri.



Peran Manajemen Atas

Mengesahkan kebijakan, menetapkan tanggal efektif, menunjuk penanggung jawab implementasi, & memastikan review berkala minimal tahunan.

Workshop 3 (30 Menit)

- 1 Susun draf klausul kebijakan keamanan arsip (maks. 2 halaman).
- 2 Petakan minimal 3 kontrol ISO 27001 yang relevan dengan unit Anda.
- 3 Integrasikan 1 klausul pendukung prinsip TARIF.

Portofolio 3

Rancangan Kebijakan Keamanan Arsip Terintegrasi ISMS.

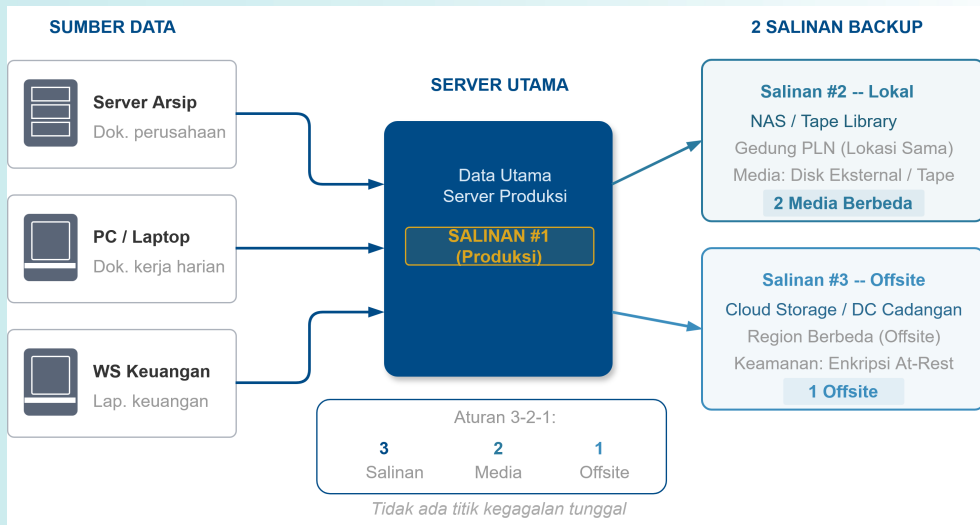
Kriteria: 4.4.3 – keselarasan ISO 27001, Zero Trust/Least Privilege, integrasi GCG BUMN.

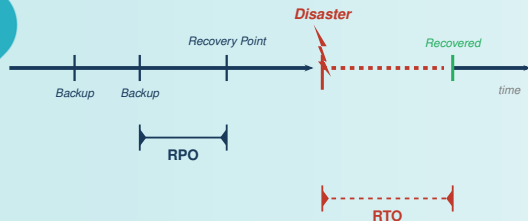
Pilar 4:

Backup & Disaster Recovery

Terintegrasi

Modul 4.4: Keamanan & Keterlacakan Terintegrasi

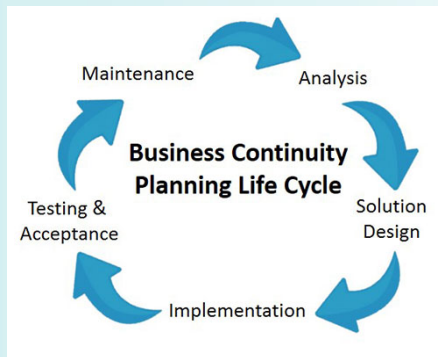




Klasif.	RTO	RPO	Strategi
Vital	<4 jam	<1 jam	Mirror site, fail-over otomatis
Rahasia	<12 jam	<4 jam	Backup harian terenkripsi
Internal	<24 jam	<12 jam	Backup mingguan, cold storage

Keputusan Bisnis

RTO/RPO = keputusan strategis, bukan teknis semata.
Proporsional dengan klasifikasi & anggaran.



5 Fase Iteratif

- 1 **Analysis** – BIA & penilaian risiko.
- 2 **Solution Design** – Strategi pemulihan.
- 3 **Implementation** – SOP, tim, infrastruktur.

Pemeliharaan

- 4 **Testing & Acceptance** – Simulasi & validasi.
- 5 **Maintenance** – Update berkala.

Simulasi minimal 6 bulan sekali!

Tata Kelola

- 1 **BIA** – Identifikasi arsip vital & estimasi dampak.
- 2 **Tetapkan RTO/RPO** – Realistis & proporsional anggaran.
- 3 **Strategi 3-2-1** – Setujui alokasi anggaran (cloud, offsite, enkripsi).

Kesiapan Organisasi

- 4 **Prosedur Fallback** – Jika sistem lumpuh >4 jam, bagaimana unit beroperasi?
- 5 **Simulasi Berkala** – Minimal 6 bulanan; MA terima laporan hasil.

Pertanyaan Kunci: “Jika arsip vital musnah besok, berapa kerugian finansial & apakah kita siap hadapi regulator?”

Workshop 4 (30 Menit)

- 1 Tentukan klasifikasi arsip vital di unit Anda.
- 2 Tetapkan target RTO/RPO realistis.
- 3 Rancang jadwal backup & skenario simulasi 6 bulanan.

Portofolio 4

Matriks RTO/RPO + Rencana Backup & DR.

Kriteria: 4.4.4 – kesesuaian 3-2-1, target realistis, prosedur fallback/simulasi.

Studi Kasus:

Insiden Kebocoran Arsip Kontrak

Modul 4.4: Keamanan & Keterlacakan Terintegrasi

Kejadian

Senin pukul 08.00, Manajer Keuangan Unit Bisnis PLN XYZ menemukan bahwa dokumen kontrak jangka panjang dengan vendor strategis telah **diunduh oleh 3 orang tidak berwenang** pada Jumat malam pukul 23.45.

- Status dokumen: **Rahasia**.
- Deteksi baru terjadi setelah **2,5 hari**.
- Staf administrasi memeriksa log & menemukan anomali secara kebetulan.

Pertanyaan Strategis

Apakah keempat pilar keamanan kita berfungsi? Di mana letak kelemahan sistemiknya?

Pilar 1: RBAC

Temuan: Ketiga pelaku berperan Staf Administrasi — seharusnya hanya Read, bukan Export.

- **Akar:** Matriks RBAC tidak membedakan View vs Export.
- **Tindakan:** Revisi matriks; pisahkan hak. Export Rahasia hanya via prosedur darurat.

Pilar 2: Audit Trail

Temuan Positif: Aksi download tercatat lengkap (who, when, where).

- **Akar:** Tidak ada alert otomatis untuk ekspor di luar jam kerja (23.45 = mencurigakan).
- **Tindakan:** Tetapkan aturan SIEM: alert otomatis untuk event kritis.

Pilar 3: Kebijakan ISMS

Temuan: Kebijakan tidak mengatur spesifik ekspor terkontrol untuk arsip Rahasia.

- **Akar:** Kebijakan belum direview 18 bulan (melampaui siklus tahunan ISO 27001).
- **Tindakan:** Revisi klausul ekspor, tetapkan jadwal review, libatkan stakeholders.

Pilar 4: Backup/DR

Temuan Positif: Arsip masih tersedia — integritas data tidak terganggu.

- **Pertanyaan Kritis:** Jika ini *ransomware*, berapa lama pemulihan? Apakah backup terpisah dari jaringan produksi?
- **Tindakan:** Verifikasi 3-2-1 & simulasi pemulihan <6 bulan terakhir.

Sistem Terintegrasi, Bukan Parsial

Kelemahan pada satu pilar akan menetralkan kekuatan pilar lainnya:

- RBAC tidak detail (Pilar 1) → celah akses.
- Tanpa pemantauan aktif (Pilar 2) → pelanggaran terlambat terdeteksi.
- Tanpa kebijakan spesifik (Pilar 3) → tidak ada dasar hukum tindak lanjut.
- Tanpa backup teruji (Pilar 4) → dampak besar tidak dapat dipulihkan.

Refleksi Mandiri

Identifikasi minimal **2 celah keamanan** yang berpotensi terjadi di unit Anda. Tentukan tindakan perbaikan per pilar, PIC, & timeline.

Validasi, Portofolio & Executive Tollgate

Modul 4.4: Keamanan & Keterlacakan Terintegrasi

Pilar	Target Kompetensi	Portofolio Wajib	Bobot
1	RBAC terintegrasi dengan kepegawaian	Matriks RBAC + Prosedur Akses	25%
2	Audit trail otomatis	Alur Audit + Template 14 Field	25%
3	Kebijakan terintegrasi ISMS	Rancangan Kebijakan Keamanan	25%
4	Backup & DR terintegrasi	Matriks RTO/RPO + Rencana DR	25%

Kriteria Kelulusan

- Skor portofolio $\geq 70/100$
- Post-test ≥ 65
- Komitmen tindak lanjut tertulis

Pengingat

Keempat portofolio bersifat **kumulatif & terintegrasi**. Pilar 1 menjadi input Pilar 2, yang menjadi input Pilar 3, dan seterusnya.

1

Legal Compliance

2

Data Integrity

3

Operational Value

4

Scalability

Kriteria Verifikasi

G1 Selaras PP 71/2019 & Perka ANRI 6/2021?

G2 Jamin keaslian via Hash + TTE + Audit Immutable?

G3 Mitigasi risiko terkuantifikasi (downtime ↓, temuan audit →0)?

G4 Infrastruktur & prosedur siap diskalakan jangka panjang?

Aturan Emas

Jika **salah satu gate** bernilai “No”, lakukan perancangan ulang sebelum diajukan ke Komite Tata Kelola.

Pertanyaan Refleksi Mandiri

- 1 Apa **1 celah keamanan** paling kritis di unit Anda saat ini?
- 2 Siapa **pemangku kepentingan kunci** (IT, GCG, Legal, SPI) yang harus dilibatkan?
- 3 Berapa **timeline realistis** untuk merampungkan 4 portofolio ini?

Lembar Komitmen 30 Hari

Saya, _____, menyatakan akan menginisiasi perbaikan keamanan arsip pada proses _____ dengan target KPI _____ dan melaporkan hasil kepada _____ paling lambat tanggal _____.

TERIMA KASIH

Mari Menuju Tata Kelola Arsip yang Aman, Terlacak, & Tahan Audit!

“Keamanan hari ini untuk keandalan hari esok.”

Langkah Selanjutnya

- Kerjakan **Post-Test** (10 soal)
- Kumpulkan **4 Portofolio** sesuai rubrik penilaian
- Jadwalkan **Peer Review** antar unit
- Gunakan hasil sebagai acuan **Rencana Peningkatan Tahunan**

